Corso di Cybersecurity – Epicode

Report dell'Esercitazione

Laboratorio di analisi malware con FlareVM

Preparazione dell'ambiente, persistenza nel registro e triage degli IOC di cinque campioni

A cura di:

Nicola Madonna

Epicode

3 agosto 2026

Indice

1 Riassunto 2
2 Obiettivi 2
3 Configurazione del Laboratorio 3
3.1 Ambiente 3
3.2 Snapshot di ripristino 3
3.3 Download del repository di campioni 4
4 Analisi dei Dati Raccolti 5
4.1 Simulazione di una persistenza nel registro 5
4.2 Triage dei campioni e identificazione degli IOC 6
5 Conclusioni 11

1 Riassunto

Questo laboratorio copre le prime fasi di un'analisi malware: preparazione di un ambiente sicuro, simulazione di una tecnica di persistenza e triage di campioni reali per estrarne gli Indicatori di Compromissione (IOC). Sulla macchina virtuale FlareVM sono stati creati gli snapshot di ripristino ed è stato scaricato un repository pubblico di campioni malware. È stata poi creata a mano una voce nella chiave di registro `HKCU\...\Run`, verificando che il programma indicato si avvii automaticamente al login. Infine cinque campioni (due ransomware, due RAT e un trojan) sono stati analizzati su VirusTotal a partire dal loro hash SHA-256.

Il risultato più interessante è trasversale: in nessuno dei cinque campioni è stato osservato un server di comando e controllo (C2) con un indirizzo fisso e facilmente bloccabile. Due campioni usano meccanismi che rendono inefficace il blocco statico, cioè domini generati da un algoritmo (DGA) e un tunnel attraverso un servizio legittimo come ngrok; per gli altri tre la sandbox non ha rilevato alcun C2.

2 Obiettivi

- Predisporre un ambiente di analisi isolato e ripristinabile.
- Popolare il laboratorio con campioni malware reali in modo controllato.
- Riprodurre una tecnica di persistenza comune per riconoscerla poi nei report di analisi.
- Estrarre e interpretare gli IOC di cinque campioni e collegarli alle tecniche MITRE ATT&CK.

3 Configurazione del Laboratorio

3.1 Ambiente

Il laboratorio è basato su **FlareVM**, la distribuzione di strumenti per l'analisi malware di Mandiant installata su una macchina virtuale Windows. La macchina lavora isolata e viene riportata a uno stato pulito tramite snapshot. L'analisi dei campioni è stata svolta solo in modo statico e tramite i report pubblici di VirusTotal, senza eseguire i malware.

3.2 Snapshot di ripristino

Prima di qualsiasi operazione rischiosa, come scaricare e decomprimere campioni o modificare il registro, sono stati creati due snapshot della macchina: **Clear**, di base, e **Clear1**, a macchina configurata e pronta all'uso (Fig. 1). In caso di problemi è possibile tornare in pochi secondi a un ambiente pulito, senza reinstallare FlareVM.



Figura 1: Snapshot della macchina virtuale FlareVM: Clear e Clear1, con lo stato attuale successivo.

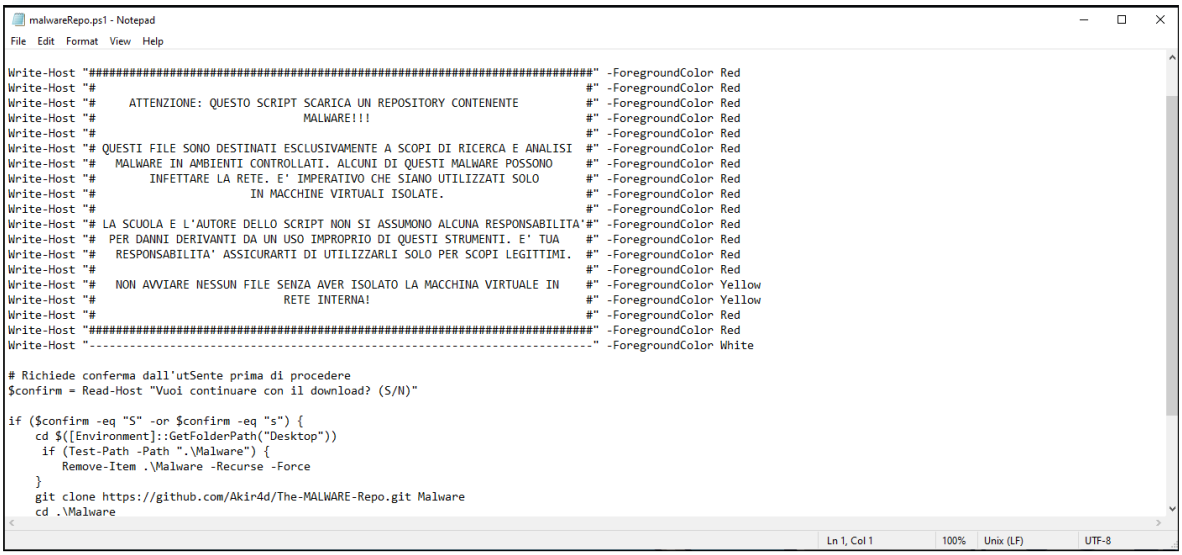


Figura 2: Contenuto dello script malwareRepo.ps1: avviso di sicurezza, richiesta di conferma e clonazione del repository.

3.3 Download del repository di campioni

Per popolare il laboratorio è stato eseguito lo script `malwareRepo.ps1` presente sul Desktop (Fig. 2). Lo script mostra un avviso sui rischi dell'uso di malware reali, chiede una conferma esplicita (S/N), si sposta sul Desktop, rimuove un'eventuale cartella *Malware* preesistente e clona un repository pubblico di campioni:

```
git clone https://github.com/Akir4d/The-MALWARE-Repo.git Malware
```

Al termine la cartella *Malware* contiene i campioni organizzati per categoria (Banking-Malware, Ransomware, RAT, Spyware, Trojan, Worm e altre) e alcuni file singoli (Fig. 3).

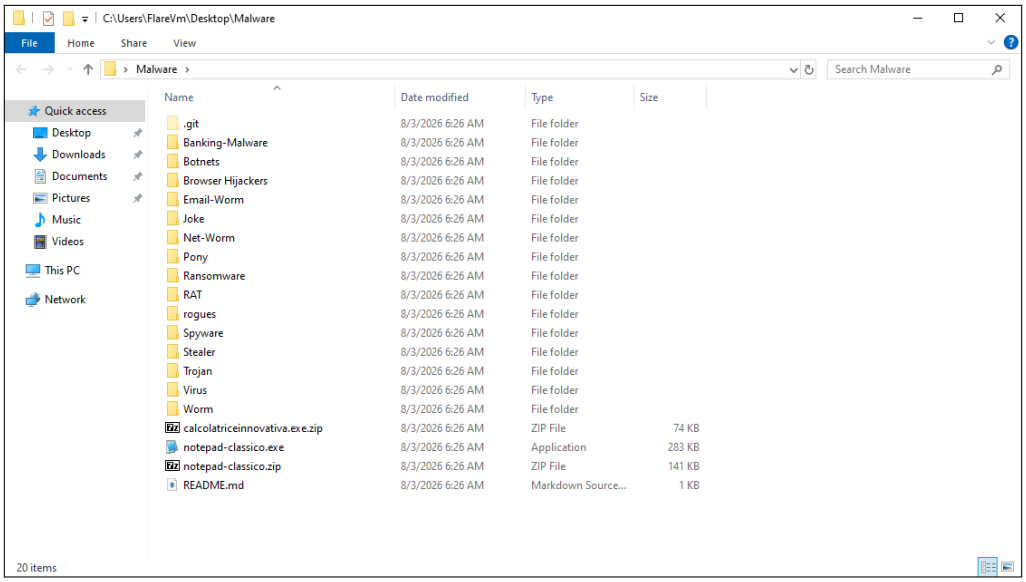


Figura 3: Cartella Malware dopo l'esecuzione dello script, con i campioni suddivisi per categoria.

4 Analisi dei Dati Raccolti

4.1 Simulazione di una persistenza nel registro

Una delle tecniche di persistenza più usate dai malware è aggiungere una voce nella chiave di registro **Run**, che fa eseguire automaticamente un programma a ogni login dell'utente. Per osservarla in modo sicuro, la tecnica è stata riprodotta a mano con un programma innocuo, la Calcolatrice di Windows.

1. Apertura di `regedit` e navigazione fino a `HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run`.
2. Creazione di un valore di tipo `REG_SZ` con nome **Calculator** e dati `C:\Windows\System32\calc.exe` (Fig. 4).
3. Riavvio della macchina virtuale e verifica dell'avvio automatico della Calcolatrice al login (Fig. 5).

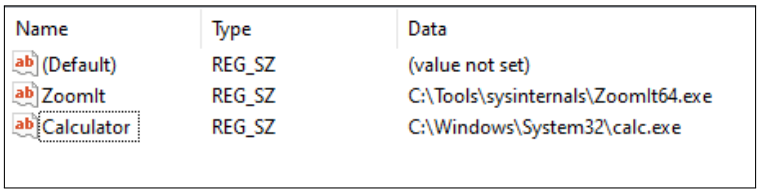


Figura 4: Chiave Run con il valore Calculator che punta a calc.exe.

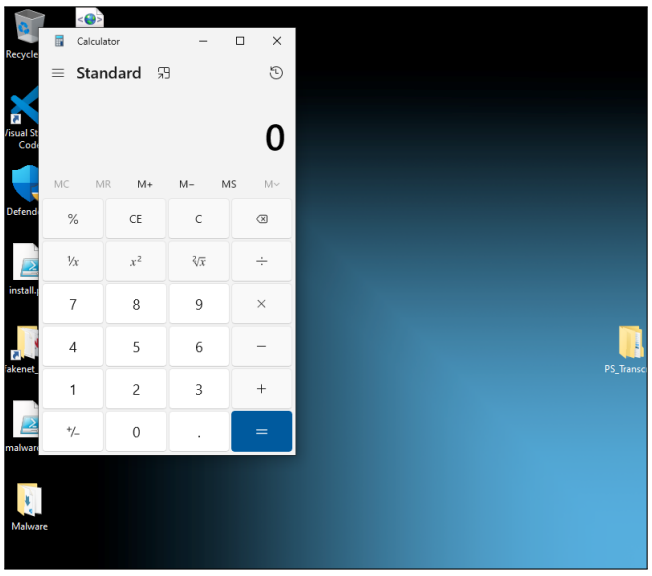


Figura 5: Dopo il riavvio la Calcolatrice si apre da sola al login.

Al riavvio la Calcolatrice si è aperta senza alcun intervento: la voce creata in `HKCU\...\Run` è stata eseguita dal sistema. È la tecnica **T1547.001 – Registry Run Keys / Startup Folder** di MITRE ATT&CK. Il test mostra che per ottenere persistenza non servono privilegi elevati: la chiave si trova nel ramo dell'utente corrente e basta poterci scrivere. Per questo le chiavi Run sono uno dei primi punti da controllare durante un'indagine e compaiono spesso tra i comportamenti segnalati dalle sandbox.

4.2 Triage dei campioni e identificazione degli IOC

4.2.1 Metodo

Dal repository sono stati scelti cinque campioni di tre categorie: **ransomware** (CryptoLocker.exe, Dharma.exe), **RAT** (CrimsonRat.exe, RevengeRAT.exe) e **trojan** (FlashKiller.exe). Per ciascuno è stato calcolato l'hash SHA-256, cercato su VirusTotal e letto nelle schede *Detection*, *Relations* e *Behavior*. I valori riportati sono quelli osservati su VirusTotal al momento dell'analisi e possono cambiare nel tempo.

Una premessa di metodo: i nomi dei file del repository sono etichette scelte da chi ha creato la raccolta e non garantiscono la famiglia reale del malware. Le detection dei vendor e il comportamento osservato in sandbox sono più affidabili del nome del file.

4.2.2 CryptoLocker.exe (ransomware)

Tabella 1: IOC identificati per CryptoLocker.exe.

Campo	**Dettaglio**
SHA-256	`d765e722e295969c0a5c2d90f549db8b89ab617900bf4698db41c7cdad993bb9`
Detection	65/69
Domini contattati	`ngoefjwghdxmtq.biz` (3/70), `swciqckbecjat.co.uk` (2/70): nomi casuali, tipici di un DGA
Persistenza	tag *persistence*
Comportamento	1.262 query DNS, tag *nxdomain* e *via-tor*; file creati: un eseguibile PE e un file RTF; regole IDS e Sigma di severità alta

CryptoLocker è considerato il capostipite del ransomware moderno (2013), il primo a unire una cifratura robusta al pagamento in criptovaluta; la sua infrastruttura originale fu smantellata nel 2014 con l'operazione *Tovar*. Le detection dei vendor sono coerenti tra loro (*Filecoder*, *Encoder*, *Trojan-Ransom*) e indicano la capacità di cifrare file. Le 1.262 query DNS verso domini alfanumerici casuali sono la firma di un **DGA**: il malware genera continuamente nuovi domini, così che bloccare quelli noti non basti. Il tag *nxdomain* indica che quasi tutte le risoluzioni falliscono, come ci si aspetta da un campione vecchio la cui infrastruttura non esiste più. Il file RTF creato è con buona probabilità la richiesta di riscatto.

Tecniche MITRE: T1486 (Data Encrypted for Impact), T1568.002 (Domain Generation Algorithms), T1090.003 (Multi-hop Proxy, tramite Tor).

4.2.3 Dharma.exe (ransomware)

Tabella 2: IOC identificati per Dharma.exe.

Campo	**Dettaglio**
SHA-256	`6fb303dd8ba36381948127d44bd8541e4a1ab8af07b46526ace08458f2498850`
Detection	59/69
Domini contattati	`epoolsoft.com`, sito dello strumento legittimo PCHunter
Persistenza	tag *calls-wmi*, possibile persistenza tramite WMI
Comportamento	tag *spreader* e *self-delete*; 6 firme MITRE di severità alta, il valore più alto del set; circa 150 file creati, tra cui uno JavaScript e un eseguibile PE

Dharma (noto anche come CrySiS) è una famiglia attiva dal 2016 e distribuita come Ransomware-as-a-Service; il suo vettore d'ingresso caratteristico è l'accesso RDP esposto su Internet con credenziali deboli. Il dato più interessante è il contatto con `epoolsoft.com`: PCHunter è uno strumento legittimo di ispezione di processi e kernel, che gli operatori usano per terminare antivirus ed EDR prima della cifratura. È un esempio di abuso di uno strumento *dual-use*. Il tag *spreader* è coerente con la cifratura di condivisioni di rete, *calls-wmi* con ricognizione ed esecuzione remota, *self-delete* con la rimozione delle tracce. Il numero di file creati suggerisce una catena in più fasi.

Tecniche MITRE: T1486 (Data Encrypted for Impact), T1562.001 (Disable or Modify Tools), T1047 (Windows Management Instrumentation), T1070.004 (File Deletion), T1021.001 (Remote Desktop Protocol).

4.2.4 CrimsonRat.exe (RAT)

Tabella 3: IOC identificati per CrimsonRat.exe.

Campo	**Dettaglio**
SHA-256	`dc31e710277eac1b125de6f4626765a2684d992147691a33964e368e5f269cba`
Nome su disco	`hbraeiwas.exe` (stringa casuale)
Detection	59/69
C2	nessun C2 esterno evidente; contatti verso la rete locale 192.168.0.x
Persistenza	nessuna chiave specifica individuata
Comportamento	tag *assembly*, *spreader*, *service-scan*; la sandbox lo classifica come RAT ed *evader* (*detect-debug-environment*, *long-sleeps*); oltre 97 file creati, tra cui un archivio ZIP e un eseguibile PE

CrimsonRAT è associato al gruppo APT36 (*Transparent Tribe*), che ha colpito soprattutto enti governativi e militari nel subcontinente indiano; è scritto in .NET e viene distribuito di solito tramite documenti Office malevoli. Il tag *assembly* conferma la natura .NET. Il nome casuale del file serve a eludere i controlli basati sul nome. I tag *service-scan* e

spreader, insieme ai contatti verso 192.168.0.x, indicano una ricognizione della rete locale, utile a individuare altri obiettivi. Le funzioni di rilevamento del debugger e le lunghe attese servono a ingannare le sandbox.

Tecniche MITRE: T1219 (Remote Access Software), T1046 (Network Service Discovery), T1497 (Virtualization/Sandbox Evasion), T1105 (Ingress Tool Transfer).

4.2.5 RevengeRAT.exe (RAT)

Tabella 4: IOC identificati per RevengeRAT.exe.

Campo	**Dettaglio**
SHA-256	`9b4826b8876ca2f1378b1dfe47b0c0d6e972bf9f0b3a36e2 99b26fbc86283885`
Detection	58/70
C2	`tcp://0.tcp.ngrok.io:19521/`, tunnel attraverso il servizio ngrok
Persistenza	tag *persistence* e *calls-wmi*
Comportamento	tag *obfuscated*, *exploit*, *ssh-communication*; una regola Sigma critica e 7 alte, il profilo più severo del set; creato un file LNK e oltre 414 altri file

RevengeRAT è un RAT *commodity* in .NET, diffuso a costo zero o quasi sui forum dal 2016 e per questo molto usato anche da attaccanti poco esperti. L'IOC più significativo dell'intero laboratorio è l'indirizzo `0.tcp.ngrok.io:19521`. Ngrok è un servizio legittimo che espone un servizio locale su un indirizzo pubblico: un attaccante senza IP statico né server dedicato può così ospitare il C2 sul proprio computer. Dal punto di vista difensivo, bloccare l'IP è inutile, perché appartiene a ngrok ed è condiviso con molti utenti legittimi; è più efficace monitorare le risoluzioni DNS verso `*.ngrok.io` o bloccare i servizi di tunneling dove non servono. Il file LNK creato è coerente con la persistenza tramite la cartella di Esecuzione automatica, alternativa alle chiavi Run.

Tecniche MITRE: T1219 (Remote Access Software), T1572 (Protocol Tunneling), T1547.001 (Registry Run Keys / Startup Folder), T1027 (Obfuscated Files or Information).

4.2.6 FlashKiller.exe (trojan)

Tabella 5: IOC identificati per FlashKiller.exe.

Campo	**Dettaglio**
SHA-256	`353df4f186c06a626373b0978d15ec6357510fd0d4ac54b6 3217b37142ab52d3`
Nome su disco	`Retrac cheet.exe`
Dimensione	circa 4 KB
Detection	61/70, la più alta del set
C2	nessun C2 esterno evidente; contatti verso la rete locale 192.168.0.x
Persistenza	nessuna persistenza esplicita rilevata
Comportamento	comportamento dinamico minimo: solo 9 segnalazioni informative, nessuna firma di severità bassa, media o alta; tag *overlay* e *checks-user-input*

Il nome non riconduce a una famiglia documentata, quindi i dati più utili sono la dimensione e il comportamento. Con circa 4 KB è difficile che il file contenga un payload completo: è più probabilmente un *downloader* o *dropper*, il cui compito è scaricare ed eseguire il codice vero da un server remoto. Questo spiegherebbe la discrepanza tra la detection statica altissima e un comportamento dinamico quasi nullo. Le spiegazioni più probabili sono due: il server di download non è più attivo, per cui il campione non ha nulla da eseguire, oppure il file attende un'interazione umana prima di attivarsi (tag *checks-user-input*), che molte sandbox non simulano. Il tag *overlay* indica dati aggiunti in coda al file, spesso configurazioni, URL o un payload cifrato.

Tecniche MITRE: T1105 (Ingress Tool Transfer), T1497.002 (User Activity Based Checks).

4.2.7 Sintesi comparativa

Tabella 6: Confronto tra i campioni analizzati.

Aspetto	**Campione più rappresentativo**
Impatto distruttivo	CryptoLocker e Dharma (cifratura dei dati)
Severità del comportamento	RevengeRAT (regola Sigma critica)
Resilienza del C2	CryptoLocker (DGA) e RevengeRAT (tunnel ngrok)
Disattivazione delle difese	Dharma (abuso di PCHunter contro antivirus ed EDR)
Ricognizione della rete locale	CrimsonRat e FlashKiller (contatti verso 192.168.0.x)
Elusione delle sandbox	FlashKiller (comportamento quasi nullo) e CrimsonRat (evader)

L'osservazione trasversale più importante riguarda il C2: in nessun campione è stato osservato un indirizzo IP fisso. Dove un C2 è emerso, DGA e tunneling rendono inefficace il blocco statico. È il motivo per cui la ricerca delle minacce si è spostata dagli IOC atomici, come hash e indirizzi IP, agli indicatori comportamentali: un hash cambia a ogni

ricompilazione, mentre un processo che esegue oltre mille query DNS fallite in pochi secondi resta riconoscibile su tutta la famiglia. Anche la persistenza ritorna in più campioni (CryptoLocker, Dharma, RevengeRAT), segnalata dai tag *persistence* e *calls-wmi*: è la categoria di tecnica riprodotta a mano con la chiave Run, anche se i tag non indicano quale meccanismo preciso usi ciascun campione.

4.2.8 Limiti dell'analisi

- L'analisi si basa sui report di VirusTotal e non sull'esecuzione diretta dei campioni: i comportamenti riportati sono quelli osservati dalle sandbox del servizio.
- Detection, tag e relazioni di VirusTotal cambiano nel tempo, man mano che nuovi motori e sandbox analizzano i file.
- Le informazioni sulle famiglie (origine, gruppi associati, vettori tipici) provengono da fonti pubbliche e servono come contesto, non come attribuzione certa dei singoli campioni.

5 Conclusioni

Il laboratorio ha percorso il flusso tipico di un'analisi malware preliminare: preparazione di un ambiente isolato e ripristinabile, raccolta dei campioni, sperimentazione di una tecnica di persistenza ed estrazione degli IOC con la loro contestualizzazione nelle tecniche MITRE ATT&CK.

Creare a mano la chiave Run ha reso concreto un concetto che nei report di VirusTotal compare solo come un'etichetta: i tag *persistence* osservati nei campioni indicano la stessa categoria di tecnica, anche se non il meccanismo preciso. Dal triage dei cinque campioni emerge invece il limite degli IOC atomici. Hash e IP si cambiano facilmente; le tecniche e i comportamenti restano, ed è su questi che conviene costruire regole di rilevamento e attività di threat hunting.

Infine, il laboratorio conferma l'importanza di un ambiente di analisi isolato: lavorare su campioni reali senza snapshot e senza isolamento di rete metterebbe a rischio non solo la macchina di analisi, ma l'intera rete circostante.